

SMART FACTORY

Cybersecurity Threat & Risk Assessment

Client: Apex Manufacturing Ltd. - Plant 1 (single-site automotive components plant)

STRIDE threat model | 5x5 risk assessment | IEC 62443 / NIST mapping

Version	1.0
Date	October 2026
Prepared by	K. Giannopoulou
Classification	Confidential - fictional case study for portfolio use

*Apex Manufacturing Ltd., RoboServ Automation GmbH and all systems described are fictional.
Prepared as a portfolio work sample; no real organisation was assessed.*

Document control

Version	Date	Author	Change
0.1	September 2026	K. Giannopoulou	Scope, architecture and asset inventory
0.5	September 2026	K. Giannopoulou	DFD, STRIDE analysis, attack scenarios
1.0	October 2026	K. Giannopoulou	Risk scoring, recommendations, roadmap - issued

Contents

1. Executive summary	4
2. Scope	5
3. Factory architecture	5
4. Critical assets	7
5. Trust boundaries	7
6. Data flow diagram	9
7. Threat modelling methodology	10
8. STRIDE analysis	11
9. Attack scenarios	13
10. Risk assessment	15
11. Top risks	16
12. Security control recommendations	17
13. IEC 62443 / NIST mapping	18
14. Remediation roadmap	19
15. Residual risk	21
16. Conclusion	21
Appendix A - STRIDE threat register	22
Appendix B - Asset inventory	25
Appendix C - Data flows	26

1. Executive summary

Apex Manufacturing Ltd. commissioned a cybersecurity threat and risk assessment of its smart-factory environment at Plant 1. The plant produces safety-relevant automotive components for two OEMs and ships ~£180,000 of finished goods per production day. The assessment modelled the plant's IT, OT, IIoT and third-party connectivity, identified threats with STRIDE, scored them on a documented 5x5 scale and produced a prioritised remediation roadmap mapped to IEC 62443 and NIST guidance.

Overall position. We identified **30 threats**. With today's controls, **5 are Critical** and **18 are High**. The plant has a firewall and an industrial DMZ, but four design decisions undermine them, so a single phished password or a compromised vendor could plausibly reach the PLCs:

- OT servers and workstations are **joined to the corporate Active Directory**. Compromising the domain therefore compromises OT (T-08).
- The IT/OT firewall still has a **'temporary' any-any rule** and direct RDP/SMB from IT (T-10).
- **Vendor remote access** uses one shared, password-only, always-on account, and an **unapproved TeamViewer** on the engineering workstation bypasses every boundary (T-01, T-24).
- The **IIoT gateway has its own LTE Internet link**, which puts it outside the security architecture (T-11).

Nothing is enforced between the supervisory network and the PLCs, which run unauthenticated protocols with key switches in REMOTE. Once an attacker is inside OT, changing PLC logic or parameters needs no further exploit. The only copies of the PLC programs sit on the engineering workstation, so recovery after ransomware or logic tampering could take weeks.

Key recommendations. The first 30 days need configuration changes only: MFA and named, disabled-by-default vendor accounts; removal of TeamViewer; firewall rule clean-up; offline PLC/HMI backups; IIoT gateway lock-down; PLC key switches to RUN. Between 30 and 90 days, rebuild the identity and network boundaries (separate OT domain, control-zone firewall, hardened jump server and engineering workstation). Over 3-12 months, add OT monitoring, formal PLC change management, PAM, OT incident response and supplier security requirements.

Rating	Current	Residual (after roadmap)
Critical	5	0
High	18	3
Medium	6	18
Low	1	9

Once the roadmap is complete, no risk remains Critical. Three remain High (vendor credentials, engineering workstation compromise and VPN appliance exploitation), because remote vendor support and PLC programming capability are business requirements. We recommend that the Plant Manager formally accepts these with the compensating measures in Section 15.

2. Scope

In scope: Enterprise zone elements that affect OT (Active Directory, IT/OT firewall, email as an entry vector); the industrial DMZ; OT site operations (SCADA/HMI, engineering workstation, historian, OPC UA); control network (three PLCs); IIoT sensors, gateway and cloud platform; RoboServ vendor remote access.

Out of scope: hardwired safety circuits (assumed independent and non-networked); CNC machine controllers; physical security beyond control cabinets; the ERP application itself.

Method: desk-based review of architecture documentation, firewall rule export and stakeholder interviews (Plant Manager, OT Engineering Lead, IT Security Manager, RoboServ service lead). No intrusive testing was performed.

Limitations: the environment is fictional. Likelihood ratings are expert judgement informed by public threat reporting, not statistical frequencies. Results depend on the stated configuration being accurate.

3. Factory architecture

Apex Manufacturing Ltd. operates 3 shifts, 24x5 production. Parts flow from CNC machining over **PLC-01 (conveyor)** to **PLC-02 (robotic welding cell)** and **PLC-03 (packaging)**. Weld and torque records are kept in the historian for IATF 16949 traceability. Two years ago, 24 wireless vibration sensors and an IIoT gateway were added for cloud-based predictive maintenance. RoboServ Automation GmbH maintains the PLC programs and robot cell remotely.

Zone	Purdue	Components
Z0 Internet	-	Untrusted public networks; vendor and attacker origin.
Z1 Enterprise	L4-L5	Corporate LAN: workstations, Active Directory, ERP, email.
Z2 Industrial DMZ	L3.5	Brokering zone between IT and OT: historian replica, jump server, remote-access gateway.
Z3 OT Site Operations	L2-L3	SCADA/HMI, engineering workstation, historian, OPC UA server.
Z4 Control	L1	PLC-01 conveyor, PLC-02 robotic welding cell, PLC-03 packaging.
Z5 Physical Process & Safety	L0	Sensors, drives, actuators; hardwired safety circuits (e-stops, light curtains, safety relays).
Z6 IIoT / Cloud	outside model	Wireless vibration sensors, IIoT gateway with LTE uplink, SaaS analytics platform.
Z7 Third-party Vendor	external	RoboServ Automation GmbH (fictional) - remote PLC and robot-cell maintenance.

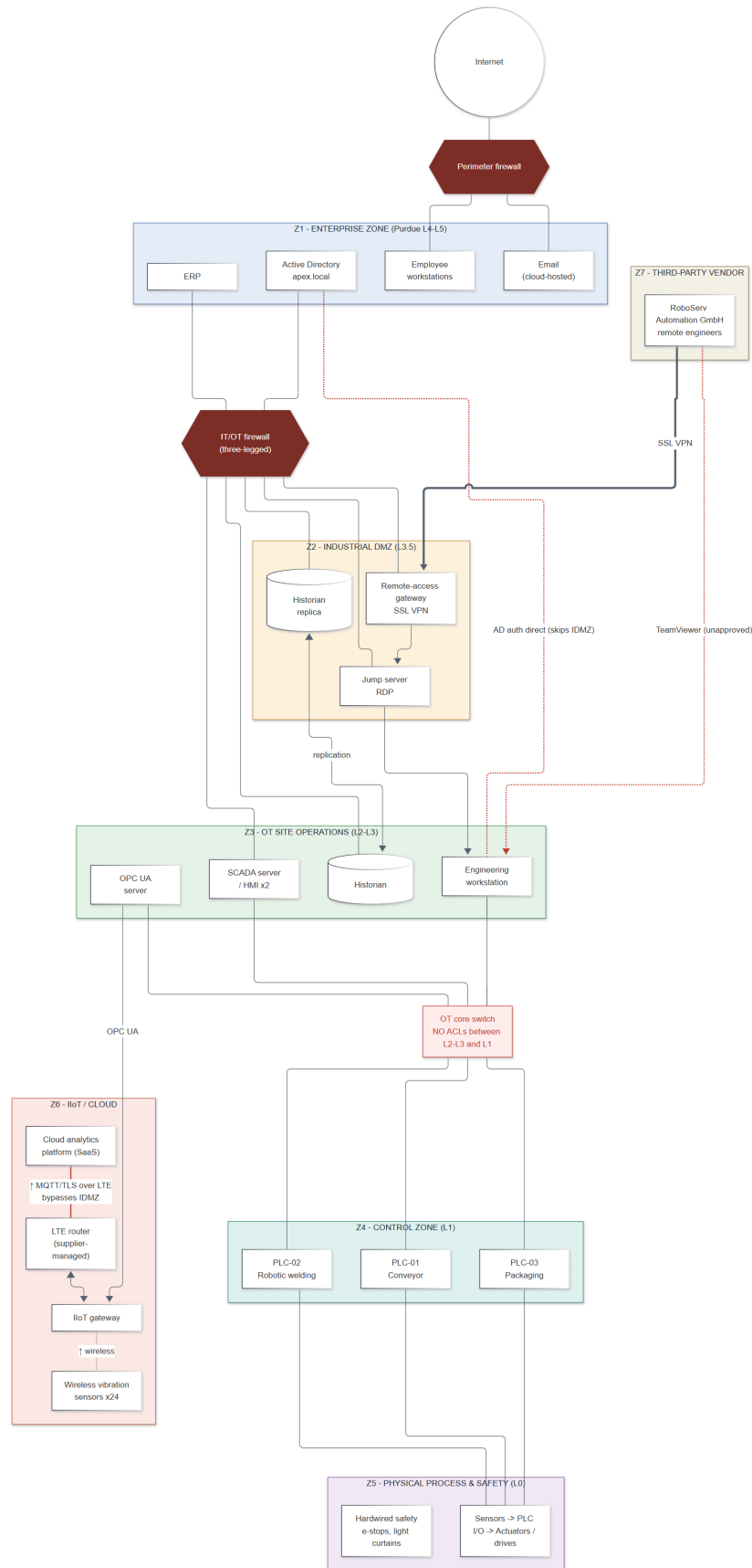


Figure 1 - As-is architecture. Red dashed lines are findings (unapproved or boundary-bypassing paths).

4. Critical assets

The full inventory of 23 assets is in Appendix B. The assets below are rated Critical: losing their integrity or availability directly stops production, affects product quality or exposes the whole OT estate.

ID	Asset	Zone	Function	Security concern
A-03	Active Directory (apex.local)	Z1	Identity and authentication for IT and (currently) OT hosts	Credential compromise grants OT access
A-06	IT/OT firewall (three-legged)	Z2	Separates Enterprise, IDMZ and OT	Permissive rules defeat segmentation
A-09	Remote-access gateway (SSL VPN)	Z2	Internet-facing VPN for vendor remote support	Internet-exposed edge device; credential attacks
A-10	SCADA server / HMI (2 operator stations)	Z3	Operator supervision and control of all three lines	Manipulated commands; loss of view
A-11	Engineering workstation (EWS)	Z3	PLC/robot programming; holds only copies of PLC projects	Malware / credential theft -> PLC logic changes
A-14	PLC-01 Conveyor	Z4	Controls material flow between machining and welding	Unauthorized logic changes / stop commands
A-15	PLC-02 Robotic welding cell	Z4	Sequences robot arm and weld controller	Parameter tampering -> defective welds, equipment damage
A-18	Hardwired safety circuits	Z5	E-stops, light curtains, door interlocks, safety relays	Out of cyber scope - not networked (assumption)

5. Trust boundaries

Zones and conduits were defined in the spirit of IEC 62443-3-2. Each trust boundary was rated on how well it is enforced today. Two boundaries, TB-4 (supervisory to PLCs) and TB-6 (OT to IIoT/cloud), are not enforced at all. Three bypass paths cross several boundaries at once.

ID	Between	Enforced by	State	Observation
TB-1	Internet (Z0) <-> Enterprise (Z1)	Perimeter firewall	Enforced	Standard IT perimeter; email and web filtering in place.
TB-2	Enterprise (Z1) <-> Industrial DMZ (Z2)	IT/OT firewall (IT-facing leg)	Partially enforced	Three-legged firewall managed by IT. Rule base contains 'temporary' any-any rule from 2024 robot-cell project and direct RDP/SMB from the IT admin subnet.
TB-3	Industrial DMZ (Z2) <-> OT Site Operations (Z3)	IT/OT firewall (OT-facing leg)	Partially enforced	Historian replication is bidirectional SQL; AD authentication traffic passes from OT hosts straight to corporate domain controllers, bypassing the DMZ.
TB-4	OT Site Operations (Z3) <-> Control (Z4)	None (routed on OT core switch, no ACLs)	Not enforced	Any OT host can reach any PLC on any port. PLCs are left in REMOTE key position.
TB-5	Control (Z4) <-> Physical Process & Safety (Z5)	Hardwired I/O; independent hardwired safety circuits	Physically enforced	Safety functions (e-stop, light curtains, door interlocks) are hardwired and not programmable from the network - assumed independent of PLC logic.
TB-6	OT (Z3) <-> IIoT / Cloud (Z6)	None by Apex (LTE router supplied by IIoT vendor)	Not enforced	IIoT gateway is dual-homed: OT network + its own LTE uplink to the Internet. This path bypasses the IDMZ entirely.
TB-7	Vendor (Z7) <-> Apex (Z2/Z3)	SSL VPN + contract	Weak	Single shared vendor VPN account, password-only, always enabled. TeamViewer found installed on the engineering workstation as an 'emergency' path.

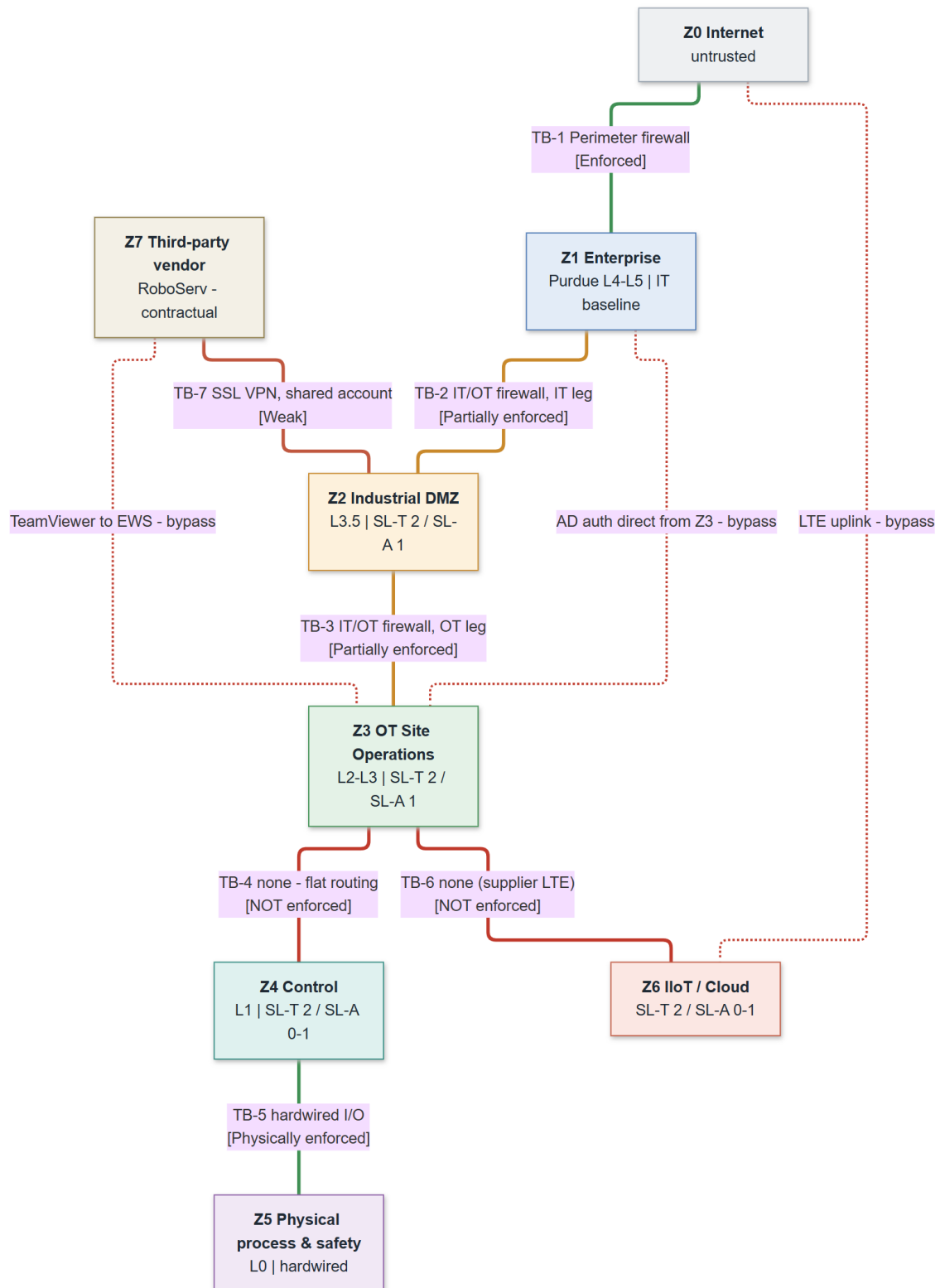


Figure 2 - Zones, conduits and trust boundaries. SL-T / SL-A are indicative target and achieved security levels.

6. Data flow diagram

The Level-1 DFD models the plant as external entities, processes, data stores and 20 numbered data flows (DF-01 to DF-20). Flows that cross a trust boundary were the main focus of the STRIDE analysis. The full flow table is in Appendix C.

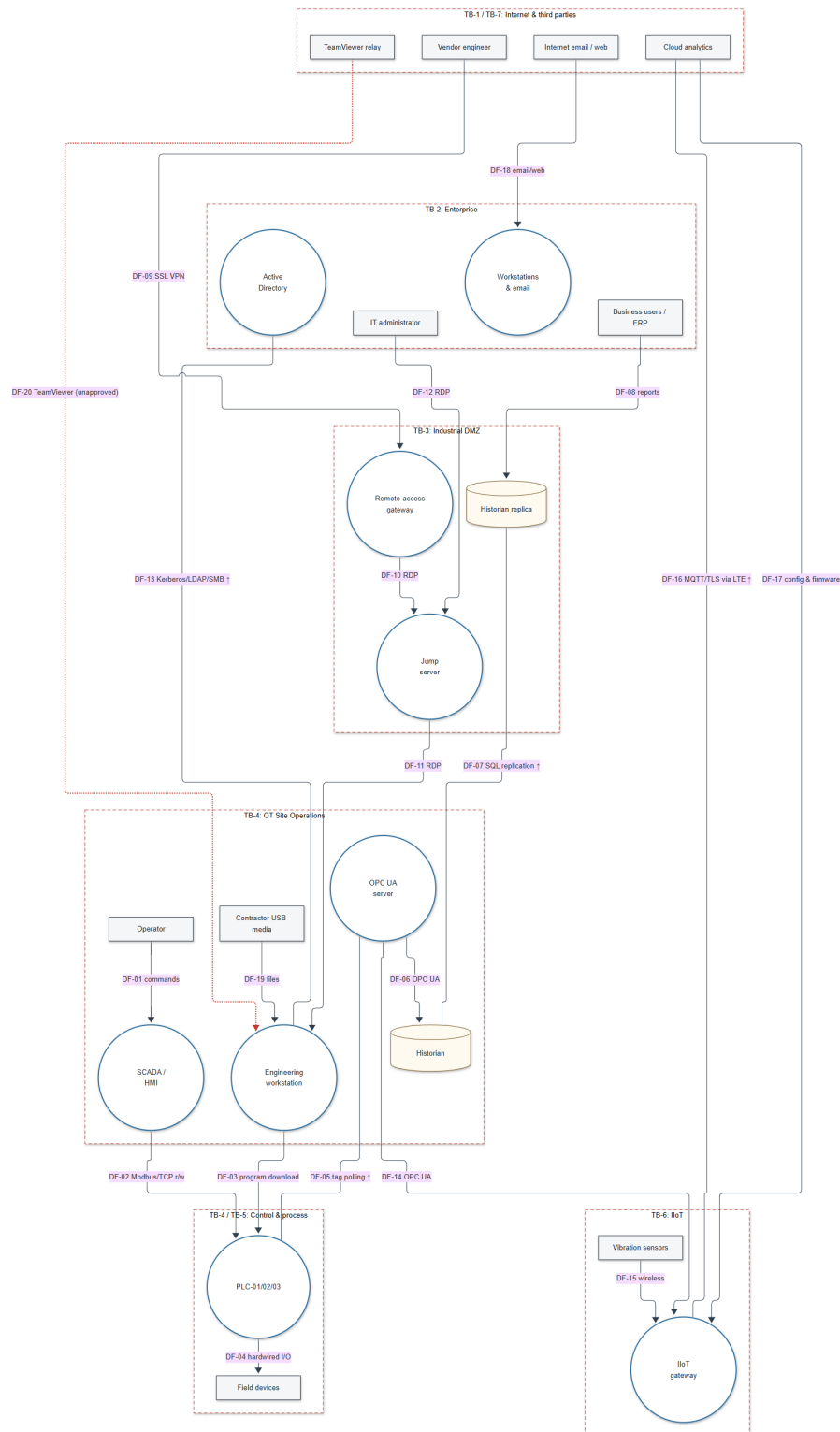


Figure 3 - Level-1 DFD. Upward flows are drawn as lines with an up-arrow in the label.

7. Threat modelling methodology

- **Model** - asset inventory, zones/conduits, DFD with numbered flows.
- **Identify** - STRIDE per element, focusing on trust-boundary crossings.
- **Chain** - combine threats into five attack scenarios mapped to MITRE ATT&CK for ICS.
- **Score** - Likelihood x Impact on documented 5x5 scales (Section 10).
- **Treat** - map controls to IEC 62443-3-3, NIST SP 800-53 (SP 800-82r3 overlay) and NIST CSF 2.0; sequence into a roadmap.

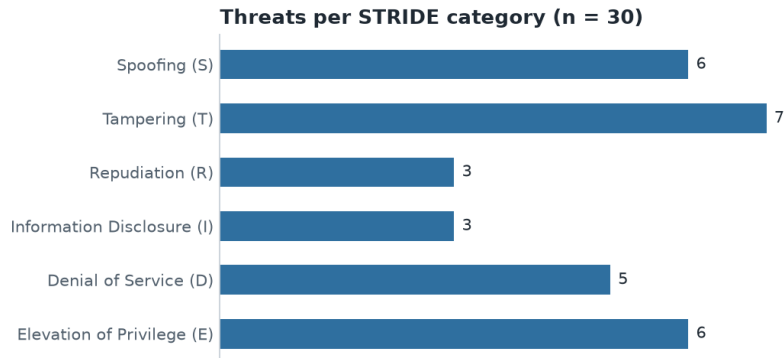
Element type	S	T	R	I	D	E
External entity	X		X			
Process	X	X	X	X	X	X
Data store		X	(logs)	X	X	
Data flow		X		X	X	

Threat actors considered

ID	Actor
TA-1	Cybercriminal / ransomware affiliate
TA-2	Initial access broker
TA-3	State-sponsored group with ICS capability
TA-4	Malicious insider
TA-5	Negligent insider or contractor
TA-6	Compromised third party / supply chain
TA-7	Opportunistic attacker / hacktivist

8. STRIDE analysis

The analysis produced 30 threats spread across all six STRIDE categories. Tampering, spoofing and elevation of privilege dominate. This is typical for OT, where integrity and the paths into Level 1 matter more than confidentiality. Appendix A has the complete register with actors, attack paths, existing controls and mitigations.



ID	Component / flow	STRIDE	Threat	Score
T-01	DF-09	Spoofing	Stolen vendor credentials used on VPN	20 Critical
T-02	DF-03	Tampering	Unauthorized PLC logic modification	15 High
T-03	DF-01	Repudiation	Operator actions cannot be attributed	12 High
T-04	DF-08	Information Disclosure	Unauthorized access to production data	9 Medium
T-05	DF-02, DF-05	Denial of Service	Network flooding disrupts PLC communications	12 High
T-06	DF-03, DF-11	Elevation of Privilege	Malware gains admin rights on engineering workstation	15 High
T-07	DF-10, DF-11, DF-12	Elevation of Privilege	Jump server used as pivot into OT	15 High
T-08	DF-13	Spoofing	Corporate AD compromise grants OT access	20 Critical
T-09	DF-18	Spoofing	Phishing email establishes enterprise foothold	15 High
T-10	DF-12, DF-13	Elevation of Privilege	Permissive IT/OT firewall rules bypass IDMZ	20 Critical
T-11	DF-14, DF-16	Elevation of Privilege	IIoT gateway LTE link bypasses IDMZ	15 High
T-12	DF-16	Information Disclosure	Production data exposed via cloud platform	9 Medium
T-13	DF-17	Tampering	Malicious firmware/config pushed from cloud	10 High
T-14	DF-15	Spoofing	Spoofed wireless sensor readings	4 Low
T-15	DF-02	Tampering	Unauthenticated Modbus write commands	15 High
T-16	DF-02, DF-03, DF-05	Information Disclosure	Sniffing of cleartext control traffic	6 Medium
T-17	DF-01, DF-02	Denial of Service	Ransomware encrypts SCADA/HMI	20 Critical
T-18	DF-06, DF-07	Denial of Service	Loss of historian quality records	12 High
T-19	DF-06	Tampering	Tampering with historian quality data	8 Medium
T-20	DF-05, DF-06, DF-14	Spoofing	Anonymous access to OPC UA server	12 High
T-21	DF-03	Denial of Service	PLC stopped via mode change or firmware flaw	12 High
T-22	DF-03, DF-02	Tampering	Covert weld-parameter manipulation (quality escape)	10 High
T-23	DF-03	Repudiation	PLC changes not logged or versioned	12 High
T-24	DF-20	Spoofing	Unapproved TeamViewer on engineering workstation	20 Critical
T-25	DF-10, DF-11, DF-12	Repudiation	Remote sessions not recorded	9 Medium
T-26	DF-09	Elevation of Privilege	Exploitation of Internet-facing VPN appliance	15 High
T-27	DF-03	Denial of Service	No usable backup of PLC programs and HMI projects	15 High

ID	Component / flow	STRIDE	Threat	Score
T-28	DF-19	Tampering	Malware introduced via removable media	12 High
T-29	DF-07	Elevation of Privilege	Historian replication used to pivot into OT	12 High
T-30	DF-02, DF-03	Tampering	Rogue device connected in control cabinet	8 Medium

9. Attack scenarios

The five scenarios below show how individual threats chain into operational consequences. Each step is mapped to MITRE ATT&CK for ICS and paired with a detection opportunity and the control that breaks the chain. The full narratives are in [threat-model/attack-scenarios.md](#).

AS-01 - Compromised vendor remote access -> PLC manipulation

Field	Detail
Threat actor	Initial access broker / ransomware affiliate
Entry point	Vendor SSL VPN
Attack path	Vendor credentials phished -> VPN login as shared account (T-01) -> jump server -> EWS (T-07, or TeamViewer T-24) -> local admin on EWS (T-06) -> PLC program download / STOP (T-02, T-21) -> no attribution (T-23, T-25).
Impact	Line stop, possible equipment damage
STRIDE	Denial of Service, Elevation of Privilege, Repudiation, Spoofing, Tampering
ATT&CK for ICS	T0822, T0859, T0886, T0843, T0858, T0813
Breaking controls	SC-01 MFA + disabled-by-default accounts; SC-07 key switch in RUN; SC-10 download alerting

AS-02 - Corporate workstation -> AD compromise -> IT/OT pivot

Field	Detail
Threat actor	Ransomware affiliate or state-sponsored group
Entry point	Phishing email
Attack path	Phishing foothold (T-09) -> AD privilege escalation (T-08) -> domain credentials valid on OT hosts -> direct RDP/SMB through permissive IT/OT rules (T-10) -> traffic capture (T-16) -> unauthenticated Modbus writes (T-15).
Impact	Unauthorized control of the lines
STRIDE	Elevation of Privilege, Information Disclosure, Spoofing, Tampering
ATT&CK for ICS	T0865, T0859, T0886, T0842, T0855, T0831
Breaking controls	SC-02 separate OT identity domain and deny-by-default IT/OT; SC-03 conduit allowlist

AS-03 - Compromised engineering workstation -> covert PLC logic change

Field	Detail
Threat actor	State-sponsored group or malicious insider
Entry point	USB media / insider
Attack path	Infected USB (T-28) -> admin on EWS (T-06) -> modified weld parameters on PLC-02 (T-02, T-22) -> parts pass inspection but fail in service -> change not attributable (T-23) and good program not recoverable (T-27).
Impact	Quality escape, OEM recall, contract loss
STRIDE	Denial of Service, Elevation of Privilege, Repudiation, Tampering
ATT&CK for ICS	T0847, T0863, T0889, T0836, T0879
Breaking controls	SC-06 USB control + allowlisting; SC-07 golden-copy compare; SC-08 offline backups

AS-04 - IIoT gateway compromise -> OT intrusion

Field	Detail
Threat actor	Opportunistic attacker or compromised IIoT supplier
Entry point	IIoT gateway LTE link
Attack path	Gateway web admin with default credentials over LTE (T-11), or malicious firmware from cloud (T-13) -> dual-homed gateway gives OT foothold -> anonymous OPC UA (T-20) -> recon (T-16) -> Modbus writes / flooding (T-15, T-05).
Impact	OT foothold outside all IT controls
STRIDE	Denial of Service, Elevation of Privilege, Information Disclosure, Spoofing, Tampering
ATT&CK for ICS	T0883, T0812, T0862, T0861, T0855, T0814
Breaking controls	SC-11 route via IDMZ, read-only gateway, signed firmware; SC-15 OPC UA security

AS-05 - Ransomware -> historian/HMI outage -> production stop

Field	Detail
Threat actor	Ransomware affiliate
Entry point	Phishing email
Attack path	Phishing -> domain admin (T-09, T-08) -> ransomware deployed to all domain hosts incl. OT (T-10, T-29) -> SCADA/HMI and historian encrypted (T-17, T-18) -> plant stops; no offline PLC/HMI backups (T-27).
Impact	Multi-day plant outage, loss of traceability
STRIDE	Denial of Service, Elevation of Privilege, Spoofing
ATT&CK for ICS	T0859, T0815, T0809, T0826, T0828 (+ Enterprise T1486)
Breaking controls	SC-02 separate OT domain; SC-08 offline backups + restore test; SC-14 OT IR

10. Risk assessment

Risk = Likelihood x Impact (1-25). Current risk reflects existing controls. Residual risk assumes the recommended controls are implemented. These scales are the documented methodology of this assessment, not a universal standard. Impact is rated on the highest applicable dimension.

Score	Likelihood	Criteria
1	Rare	Requires nation-state capability and insider access; no known precedent in the sector.
2	Unlikely	Requires significant skill plus an existing foothold; strong compensating controls in place.
3	Possible	Feasible for a motivated attacker with OT knowledge once inside; controls are partial.
4	Likely	Technique is used routinely against similar manufacturers; weak controls; low skill required.
5	Almost Certain	Trivial to exploit, directly exposed, or already observed at Apex.

Score	Impact	Criteria
1	Insignificant	No production impact; < £10k; no safety or quality effect.
2	Minor	< 4 h on one line; £10k-£50k; quality issue caught internally.
3	Moderate	4-24 h on one line or < 8 h plant-wide; £50k-£250k; limited disclosure of sensitive data.
4	Major	1-3 days plant outage; £250k-£1M; defective parts reach customer or equipment damage.
5	Severe	> 3 days outage; > £1M; potential injury, product recall or loss of OEM contract.

Range	Rating	Expected response
17-25	Critical	Senior-management attention; mitigate within 30 days
10-16	High	Mitigation plan within 90 days
5-9	Medium	Mitigate within 12 months or formally accept
1-4	Low	Accept and monitor

Apex Manufacturing - 5x5 risk matrix (numbers = threat IDs T-xx)

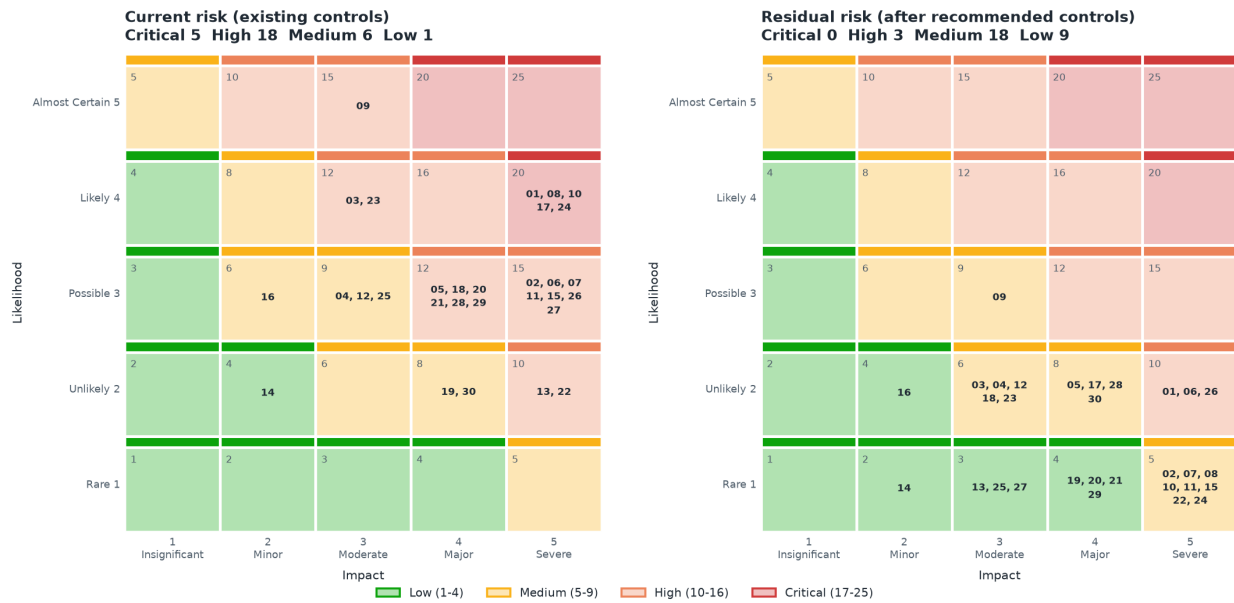


Figure 4 - Risk matrix before and after treatment. Numbers in cells are threat IDs.

11. Top risks

Ranking rule: score, then impact, then the number of attack scenarios the threat enables (chokepoints first).

#	ID	Risk	Score	Scenarios	Controls	Residual
1	T-08	Corporate AD compromise grants OT access	20 Critical	AS-02, AS-05	SC-02, SC-04	5 Medium
2	T-10	Permissive IT/OT firewall rules bypass IDMZ	20 Critical	AS-02, AS-05	SC-02	5 Medium
3	T-01	Stolen vendor credentials used on VPN	20 Critical	AS-01	SC-01, SC-04, SC-16	10 High
4	T-17	Ransomware encrypts SCADA/HMI	20 Critical	AS-05	SC-02, SC-06, SC-08, SC-14	8 Medium
5	T-24	Unapproved TeamViewer on engineering workstation	20 Critical	AS-01	SC-01, SC-06, SC-02	5 Medium
6	T-02	Unauthorized PLC logic modification	15 High	AS-01, AS-03	SC-07, SC-03, SC-10	5 Medium
7	T-06	Malware gains admin rights on engineering workstation	15 High	AS-01, AS-03	SC-06, SC-04, SC-13	10 High
8	T-15	Unauthenticated Modbus write commands	15 High	AS-02, AS-04	SC-03, SC-10	5 Medium
9	T-27	No usable backup of PLC programs and HMI projects	15 High	AS-03, AS-05	SC-08	3 Low
10	T-07	Jump server used as pivot into OT	15 High	AS-02	SC-05, SC-02, SC-04	5 Medium

12. Security control recommendations

We recommend 17 controls. Each one is traced to the threats it mitigates. They are grouped by the principle they serve: fix the boundaries before buying tools, protect the paths to Level 1, assume breach and recover quickly, and bring third parties inside the security model.

ID	Control	Description	Mitigates
SC-01	Secure vendor remote access	Named per-engineer vendor accounts, MFA on the VPN, accounts disabled by default and enabled per approved ticket, source-IP restriction, removal of unapproved remote tools (TeamViewer).	T-01, T-24, T-26
SC-02	IT/OT segmentation via the IDMZ	Deny-by-default IT/OT firewall; no direct Enterprise->OT traffic; OT hosts moved to a separate OT identity domain; OT-initiated historian push only.	T-07, T-08, T-10, T-17, T-18, T-24, T-29
SC-03	Control-zone conduit and switch hardening	Firewall between Site Operations and Control zone with protocol allowlist (SCADA/OPC -> PLC Modbus; EWS -> PLC engineering protocol only), switch port security, unused ports disabled, cabinets locked.	T-02, T-05, T-15, T-16, T-20, T-21, T-22, T-30
SC-04	Privileged access management & least privilege	Remove shared/excess admin accounts, no local admin for operators, credential vaulting and just-in-time elevation for OT and vendor admins, password rotation for service accounts.	T-01, T-06, T-07, T-08, T-12, T-29
SC-05	Hardened jump server	Jump server off the corporate domain, MFA, session recording, clipboard/drive mapping disabled by default, can only reach approved OT targets.	T-07, T-25
SC-06	Engineering workstation & HMI hardening	Application allowlisting, USB device control with a scanning kiosk, no Internet egress, OS patching in maintenance windows, unnecessary services removed.	T-06, T-17, T-24, T-28
SC-07	PLC change management & integrity	PLC key switches in RUN, REMOTE/PROG only during approved change windows; version-controlled PLC projects; scheduled online-vs-golden program compare.	T-02, T-21, T-22, T-23
SC-08	OT backup & recovery	Offline/immutable backups of PLC programs, HMI/SCADA projects, historian configuration and OT server images; quarterly restore tests.	T-17, T-18, T-27
SC-09	Centralised security logging	OT log collector in the IDMZ forwarding Windows, firewall, VPN, jump server and HMI audit logs to the SIEM; named HMI user logins.	T-03, T-04, T-19, T-23, T-25
SC-10	OT network monitoring (passive IDS)	Passive OT-aware monitoring on SPAN ports in Z3/Z4 with protocol decoding (Modbus, engineering protocol), alerting on program downloads, mode changes and new hosts.	T-02, T-05, T-15, T-16, T-22, T-26, T-30
SC-11	IIoT gateway security architecture	Remove LTE bypass; route gateway via IDMZ broker; gateway read-only toward OT; certificate-based device identity; signed firmware; inbound management disabled; default credentials removed.	T-11, T-12, T-13, T-14
SC-12	Enterprise phishing & endpoint defence	Email authentication (SPF/DKIM/DMARC) and sandboxing, EDR on corporate endpoints, awareness training with phishing simulation.	T-09
SC-13	OT asset inventory & vulnerability management	Maintained inventory of OT assets/firmware; risk-based patching with a 14-day SLA for Internet-facing devices; vendor advisory subscriptions.	T-06, T-11, T-21, T-26
SC-14	OT incident response & manual operations	OT-specific IR playbooks (ransomware, PLC manipulation), decision authority for isolating IT/OT, manual-operation procedures, annual tabletop exercise.	T-17, T-28
SC-15	Application-level access control (HMI, OPC UA, historian)	Named role-based HMI accounts, OPC UA SecurityMode SignAndEncrypt with user authentication and no anonymous access, write access removed where not needed, historian replica access by role.	T-03, T-04, T-19, T-20
SC-16	Supplier security requirements	IEC 62443-2-4 aligned security clauses for RoboServ and the IIoT/cloud provider: named accounts, MFA, breach notification, secure update process, annual review.	T-01, T-12, T-13
SC-17	Network resilience for control traffic	Broadcast/storm control and rate limiting on OT switches, QoS for control traffic, PLC communication watchdogs with fail-safe behaviour.	T-05

13. IEC 62443 / NIST mapping

IEC 62443 references are IEC 62443-3-3 system requirements unless another part is named. NIST references are SP 800-53 Rev. 5 controls as tailored by the SP 800-82 Rev. 3 OT overlay. CSF references are NIST Cybersecurity Framework 2.0 categories and subcategories.

ID	Control	IEC 62443	NIST SP 800-53	NIST CSF 2.0
SC-01	Secure vendor remote access	SR 1.1 RE2, SR 1.13, SR 2.6	AC-17, IA-2(1), IA-2(2), PS-7	PR.AA-03, GV.SC
SC-02	IT/OT segmentation via the IDMZ	SR 5.1, SR 5.2	SC-7, AC-4	PR.IR-01
SC-03	Control-zone conduit and switch hardening	SR 5.1, SR 5.2, SR 7.7	SC-7, CM-7, PE-3	PR.IR-01, PR.AA-06
SC-04	Privileged access management & least privilege	SR 1.3, SR 1.5, SR 2.1	AC-2, AC-6, IA-5	PR.AA-01, PR.AA-05
SC-05	Hardened jump server	SR 1.13, SR 2.8, SR 5.2	AC-17, AU-14, SC-7	PR.AA-03, PR.PS-04
SC-06	Engineering workstation & HMI hardening	SR 3.2, SR 2.3, SR 7.7	CM-7(5), SI-3, MP-7	PR.PS-05, PR.PS-01
SC-07	PLC change management & integrity	SR 3.4, SR 2.8, SR 1.1	CM-3, CM-5, SI-7	PR.PS-01, DE.CM-09
SC-08	OT backup & recovery	SR 7.3, SR 7.4	CP-9, CP-10	PR.DS-11, RC.RP
SC-09	Centralised security logging	SR 2.8, SR 2.12, SR 6.1	AU-2, AU-6, AU-12	PR.PS-04, DE.AE
SC-10	OT network monitoring (passive IDS)	SR 6.2	SI-4	DE.CM-01
SC-11	IIoT gateway security architecture	SR 5.2, SR 1.2, SR 3.1, SR 3.4	SC-7, IA-3, SC-8, SI-7	PR.IR-01, PR.DS-02
SC-12	Enterprise phishing & endpoint defence	n/a (Enterprise zone)	SI-3, SI-8, AT-2	PR.AT-01, DE.CM-09
SC-13	OT asset inventory & vulnerability management	SR 7.8, IEC 62443-2-3	CM-8, RA-5, SI-2	ID.AM-01, ID.RA-01
SC-14	OT incident response & manual operations	IEC 62443-2-1 (incident handling)	IR-4, IR-8, CP-2	RS.MA, RC.RP
SC-15	Application-level access control (HMI, OPC UA, historian)	SR 1.1, SR 2.1, SR 3.1, SR 4.1	AC-3, AC-6, SC-8	PR.AA-05, PR.DS-02
SC-16	Supplier security requirements	IEC 62443-2-4	SA-9, SR-6	GV.SC-05
SC-17	Network resilience for control traffic	SR 7.1, SR 7.2	SC-5	PR.IR-03

14. Remediation roadmap

Actions are sequenced by risk reduction per unit of effort. Every 0-30 day action is a low-effort configuration change that directly treats Critical risks.

0-30 days - Close the open doors

ID	Action	Controls	Owner	Effort
R-01	Enforce MFA on the VPN; replace the shared vendor account with named accounts that are disabled by default and enabled per approved ticket.	SC-01	IT Security Manager	Low
R-02	Uninstall TeamViewer from the EWS; block known remote-access tools outbound at the IT/OT firewall.	SC-01, SC-02	OT Engineering Lead	Low
R-03	Patch the remote-access gateway; restrict the VPN portal to RoboServ source IPs; subscribe to the appliance vendor's advisories.	SC-13, SC-01	IT Infrastructure	Low
R-04	Review the IT/OT firewall rule base; remove the any-any rule and direct Enterprise->OT RDP/SMB rules.	SC-02	IT Infrastructure	Low
R-05	Review privileged accounts: reduce Domain Admins, remove operator local-admin rights, rotate vendor, service and historian admin passwords.	SC-04	IT Security Manager	Low
R-06	Take offline copies of all PLC programs, HMI projects and historian configuration; verify one restore on the test bench.	SC-08	OT Engineering Lead	Low
R-07	Disable the IIoT gateway's inbound web management, change default credentials, and restrict the LTE router to the cloud endpoint only.	SC-11	OT Engineering Lead	Low
R-08	Set PLC key switches to RUN; document the procedure for REMOTE/PROG only during approved change windows.	SC-07	OT Engineering Lead	Low

30-90 days - Rebuild the boundaries

ID	Action	Controls	Owner	Effort
R-09	Move OT Windows hosts to a separate OT identity domain (no trust to apex.local); force all IT->OT access through the IDMZ.	SC-02, SC-04	IT Infrastructure	High
R-10	Install a conduit firewall between Site Operations and Control zones with a protocol allowlist; enable port security and storm control; lock cabinets.	SC-03, SC-17	OT Engineering Lead	Medium
R-11	Rebuild the jump server off-domain with MFA, session recording and an approved-target list.	SC-05	IT Security Manager	Medium
R-12	Harden the EWS and HMIs: application allowlisting, USB device control, a scanning kiosk, no Internet egress.	SC-06	OT Engineering Lead	Medium
R-13	Deploy an OT log collector in the IDMZ forwarding to the SIEM; introduce named, role-based HMI accounts.	SC-09, SC-15	IT Security Manager	Medium
R-14	Re-route IIoT data via an IDMZ broker (gateway read-only toward OT); enable OPC UA SignAndEncrypt with user authentication.	SC-11, SC-15	OT Engineering Lead	Medium
R-15	Change historian replication to OT-initiated push with a least-privilege login; restrict replica access by role.	SC-02, SC-15	IT Infrastructure	Low
R-16	Strengthen enterprise phishing defences: DMARC enforcement, attachment sandboxing, EDR on all endpoints, phishing simulations.	SC-12	IT Security Manager	Medium

3-12 months - Detect, govern, sustain

ID	Action	Controls	Owner	Effort
R-17	Deploy passive OT network monitoring with asset discovery in Z3/Z4 and integrate alerts with the SOC.	SC-10, SC-13	IT Security Manager	High
R-18	Formalise PLC change management: version-controlled projects, approval workflow, scheduled program compare against golden copies.	SC-07	OT Engineering Lead	Medium
R-19	Implement PAM for OT and vendor privileged access (vaulting, just-in-time access, approval).	SC-04, SC-01	IT Security Manager	High
R-20	Write OT incident-response playbooks and manual-operation procedures; run a ransomware + PLC-manipulation tabletop exercise.	SC-14	Plant Manager	Medium

ID	Action	Controls	Owner	Effort
R-21	Add IEC 62443-2-4 aligned security requirements to RoboServ and IIoT/cloud supplier contracts; review annually.	SC-16	Procurement	Medium
R-22	Establish OT asset inventory and vulnerability management (incl. PLC firmware plan); schedule quarterly restore tests and an annual reassessment.	SC-13, SC-08	OT Engineering Lead	Medium

15. Residual risk

After the roadmap, the profile moves from 5 Critical / 18 High / 6 Medium / 1 Low to 0 Critical / 3 High / 18 Medium / 9 Low. Most controls lower likelihood. Backups (SC-08) and the IIoT redesign (SC-11) also lower impact, because they shorten recovery time and remove the gateway's write path into OT.

Threat	Residual	Why it stays High	Compensating measures
T-01 Stolen vendor credentials	2 x 5 = 10 High	Remote vendor support is a business requirement; MFA can still be phished or approved by mistake.	Phishing-resistant MFA (FIDO2); session recording; OT IDS alerting on vendor sessions
T-06 EWS privilege escalation	2 x 5 = 10 High	The EWS must be able to program PLCs; the capability can be controlled but not removed.	Allowlisting; golden-copy compare; EWS disconnected when not in use
T-26 VPN appliance exploitation	2 x 5 = 10 High	Edge-device zero-days are outside Apex's control.	14-day patch SLA; exposure limited to vendor IPs; evaluate broker with no inbound listener

We recommend that the Plant Manager formally accepts these three residual risks, that they are reviewed at least annually, and that the assessment is repeated after the 30-90 day boundary changes are in place.

16. Conclusion

Apex's exposure comes from **how trust is connected** far more than from missing security products. A shared identity domain, a firewall rule base that has drifted, unmanaged vendor and IIoT connectivity, and a flat control network mean that ordinary IT compromises can turn into production and quality incidents. Fixing those boundaries is cheap compared with the £180k-per-day cost of an outage, and most of the first wave needs no capital spend. With monitoring, change management and tested recovery in place, the plant can keep expanding its smart-factory capabilities without taking on unmanaged risk.

Appendix A - STRIDE threat register

ID	Threat / description	STRIDE / flow	Actor	Existing controls	L x I	Mitigation	Res.
T-01	Stolen vendor credentials used on VPN An attacker who phishes or buys RoboServ credentials logs in to the SSL VPN as the shared 'roboserv' account and is indistinguishable from the vendor.	S / DF-09	TA-2, TA-1	Password-only VPN; single shared vendor account; account always enabled	4x5=20 Critical	SC-01, SC-04, SC-16	2x5=10 High
T-02	Unauthorized PLC logic modification Any host that reaches a PLC on its engineering port can download modified logic, because PLCs are in REMOTE mode and the protocol has no authentication.	T / DF-03	TA-1, TA-3, TA-4	Vendor engineering software requires a project password (offline only)	3x5=15 High	SC-07, SC-03, SC-10	1x5=5 Medium
T-03	Operator actions cannot be attributed All operators share one HMI login; setpoint changes and alarm acknowledgements cannot be tied to an individual during incident or quality investigations.	R / DF-01	TA-4, TA-5	HMI event log stored locally, overwritten after 7 days	4x3=12 High	SC-15, SC-09	2x3=6 Medium
T-04	Unauthorized access to production data All 'Domain Users' can read the historian replica, exposing recipes, cycle times and OEM quality data to any compromised corporate account.	I / DF-08	TA-1, TA-4	Domain authentication only; no role-based restriction	3x3=9 Medium	SC-15, SC-09	2x3=6 Medium
T-05	Network flooding disrupts PLC communications Broadcast storms, aggressive scanning or worm traffic on the flat OT network exhaust PLC network stacks, causing communication time-outs and line stops.	D / DF-02, DF-05	TA-1, TA-5	None; no storm control, flat network	3x4=12 High	SC-03, SC-17, SC-10	2x4=8 Medium
T-06	Malware gains admin rights on engineering workstation Engineers are local administrators on an unpatched Windows EWS; malware arriving via RDP session, USB or TeamViewer obtains full control of the PLC programming environment.	E / DF-03, DF-11	TA-1, TA-3	Signature AV with outdated definitions	3x5=15 High	SC-06, SC-04, SC-13	2x5=10 High
T-07	Jump server used as pivot into OT The jump server is joined to the corporate domain and accepts RDP from the IT admin subnet; compromised IT admin credentials give an attacker a direct route into OT.	E / DF-10, DF-11, DF-12	TA-1, TA-3	Single-factor RDP; no session recording	3x5=15 High	SC-05, SC-02, SC-04	1x5=5 Medium
T-08	Corporate AD compromise grants OT access OT servers and workstations are joined to apex.local. Stolen or forged domain credentials (pass-the-hash, Kerberoasting, golden ticket) authenticate to every OT Windows host.	S / DF-13	TA-1, TA-3	14 Domain Admin accounts incl. 3 service accounts; no tiering	4x5=20 Critical	SC-02, SC-04	1x5=5 Medium
T-09	Phishing email establishes enterprise foothold A spoofed supplier or OEM email delivers a malicious attachment or credential-harvesting link to an office user.	S / DF-18	TA-1, TA-2	Cloud email filtering; annual awareness training	5x3=15 High	SC-12	3x3=9 Medium
T-10	Permissive IT/OT firewall rules bypass IDMZ A 'temporary' any-any rule and direct RDP/SMB from the IT admin subnet let an attacker on the corporate LAN reach OT hosts without passing through the IDMZ.	E / DF-12, DF-13	TA-1, TA-3	Firewall exists but rule base not reviewed since 2023	4x5=20 Critical	SC-02	1x5=5 Medium

ID	Threat / description	STRIDE / flow	Actor	Existing controls	L x I	Mitigation	Res.
T-11	IIoT gateway LTE link bypasses IDMZ The dual-homed IIoT gateway exposes a web admin interface with default credentials over its LTE link; compromise gives an Internet-to-OT path outside every Apex control.	E / DF-14, DF-16	TA-7, TA-1	None owned by Apex; router managed by IIoT supplier	3x5=15 High	SC-11, SC-13	1x5=5 Medium
T-12	Production data exposed via cloud platform Cloud tenant misconfiguration or a compromised (single-factor) cloud console account exposes machine and production data to unauthorized parties.	I / DF-16	TA-1, TA-6	Provider-managed platform; console login password-only	3x3=9 Medium	SC-16, SC-04, SC-11	2x3=6 Medium
T-13	Malicious firmware/config pushed from cloud A compromised cloud management plane pushes malicious firmware or configuration to the gateway, turning it into an attacker-controlled device inside OT.	T / DF-17	TA-6, TA-3	Firmware signing status unknown	2x5=10 High	SC-11, SC-16	1x3=3 Low
T-14	Spoofed wireless sensor readings A rogue transmitter near the plant injects false vibration readings, triggering unnecessary maintenance or masking a real bearing failure.	S / DF-15	TA-7, TA-4	Proprietary pairing; analytics are advisory only	2x2=4 Low	SC-11	1x2=2 Low
T-15	Unauthenticated Modbus write commands Modbus/TCP has no authentication; any OT host can write coils and holding registers (start/stop, conveyor speed, robot program select).	T / DF-02	TA-1, TA-3, TA-4	None	3x5=15 High	SC-03, SC-10	1x5=5 Medium
T-16	Sniffing of cleartext control traffic Cleartext Modbus and engineering traffic reveal tag maps, logic and process behaviour, giving an attacker the reconnaissance needed for targeted manipulation.	I / DF-02, DF-03, DF-05	TA-3	None	3x2=6 Medium	SC-03, SC-10	2x2=4 Low
T-17	Ransomware encrypts SCADA/HMI Ransomware spreading from IT through domain trust and open SMB encrypts SCADA servers and HMIs; operators lose view and the plant stops production.	D / DF-01, DF-02	TA-1	AV on servers; no tested OT recovery plan	4x5=20 Critical	SC-02, SC-06, SC-08, SC-14	2x4=8 Medium
T-18	Loss of historian quality records Historian encryption or deletion destroys weld and torque records required for IATF 16949 traceability, breaching OEM contractual obligations.	D / DF-06, DF-07	TA-1	Nightly backup to a share on the same server	3x4=12 High	SC-08, SC-02	2x3=6 Medium
T-19	Tampering with historian quality data An insider with historian admin rights alters recorded weld/torque values to hide out-of-tolerance parts.	T / DF-06	TA-4	Shared historian admin account	2x4=8 Medium	SC-15, SC-09	1x4=4 Low
T-20	Anonymous access to OPC UA server OPC UA runs with SecurityMode None and anonymous login; any client can impersonate the historian or gateway, browse the address space and write to writable nodes.	S / DF-05, DF-06, DF-14	TA-1, TA-3	None	3x4=12 High	SC-15, SC-03	1x4=4 Low
T-21	PLC stopped via mode change or firmware flaw An attacker issues a CPU STOP via the engineering protocol, or exploits a published denial-of-service flaw in outdated PLC firmware.	D / DF-03	TA-1, TA-3, TA-7	Firmware not updated since commissioning (2019)	3x4=12 High	SC-07, SC-03, SC-13	1x4=4 Low

ID	Threat / description	STRIDE / flow	Actor	Existing controls	L x I	Mitigation	Res.
T-22	Covert weld-parameter manipulation (quality escape) Subtle changes to weld current or robot timing produce parts that pass visual inspection but fail in service, leading to customer recall and OEM contract loss.	T / DF-03, DF-02	TA-3, TA-4	End-of-line sample testing (1 in 200)	2x5=10 High	SC-07, SC-03, SC-10	1x5=5 Medium
T-23	PLC changes not logged or versioned No version control or change log exists for PLC programs; it is impossible to tell whether a change was made by the vendor, an engineer or an attacker.	R / DF-03	TA-4, TA-5, TA-6	Paper change request for major changes only	4x3=12 High	SC-07, SC-09	2x3=6 Medium
T-24	Unapproved TeamViewer on engineering workstation TeamViewer installed by the vendor with an unattended-access password gives anyone holding that password direct Internet access to the EWS, bypassing VPN, IDMZ and logging.	S / DF-20	TA-6, TA-1	None - unknown to IT before this assessment	4x5=20 Critical	SC-01, SC-06, SC-02	1x5=5 Medium
T-25	Remote sessions not recorded Jump server sessions are neither recorded nor centrally logged, so vendor and IT administrator actions in OT cannot be reconstructed after an incident.	R / DF-10, DF-11, DF-12	TA-4, TA-6	Windows Security log, local only	3x3=9 Medium	SC-05, SC-09	1x3=3 Low
T-26	Exploitation of Internet-facing VPN appliance Edge VPN appliances are a frequent target of mass exploitation; the gateway firmware is two releases behind, and compromise yields administrative control of the remote-access path.	E / DF-09	TA-1, TA-2, TA-3	Patching ad hoc; no exposure restriction	3x5=15 High	SC-13, SC-01, SC-10	2x5=10 High
T-27	No usable backup of PLC programs and HMI projects The only copies of PLC and HMI projects live on the EWS; if it is encrypted or logic is altered, rebuilding from vendor archives could take weeks.	D / DF-03	TA-1, TA-5	Vendor holds an archive from 2022 commissioning update	3x5=15 High	SC-08	1x3=3 Low
T-28	Malware introduced via removable media Contractors and engineers move files to the EWS and HMIs on personal USB drives, a well-documented route into air-gapped and segmented control systems.	T / DF-19	TA-5, TA-3	Policy prohibits personal USB; not technically enforced	3x4=12 High	SC-06, SC-14	2x4=8 Medium
T-29	Historian replication used to pivot into OT Bidirectional SQL replication lets a compromised replica in the IDMZ open connections to the OT historian using a privileged SQL login.	E / DF-07	TA-1, TA-3	SQL authentication with sysadmin replication login	3x4=12 High	SC-02, SC-04	1x4=4 Low
T-30	Rogue device connected in control cabinet Unlocked control cabinets contain unmanaged switches with free ports; a contractor or insider laptop plugged in gets full Layer-2 access to the PLCs.	T / DF-02, DF-03	TA-4, TA-5	Badge access to production hall only	2x4=8 Medium	SC-03, SC-10	2x4=8 Medium

Appendix B - Asset inventory

ID	Asset	Zone	Purdue	Criticality	Security concern
A-01	Perimeter firewall	Z1	L5	High	Misconfiguration exposes internal services
A-02	Employee workstations (~320)	Z1	L4	Medium	Phishing / malware foothold
A-03	Active Directory (apex.local)	Z1	L4	Critical	Credential compromise grants OT access
A-04	ERP system	Z1	L4	High	Ransomware stops order-to-ship process
A-05	Email service (cloud-hosted)	Z1	L4	Medium	Phishing delivery vector
A-06	IT/OT firewall (three-legged)	Z2	L3.5	Critical	Permissive rules defeat segmentation
A-07	Historian replica	Z2	L3.5	High	Pivot into OT via replication; data disclosure
A-08	Jump server	Z2	L3.5	High	Pivot point into OT
A-09	Remote-access gateway (SSL VPN)	Z2	L3.5	Critical	Internet-exposed edge device; credential attacks
A-10	SCADA server / HMI (2 operator stations)	Z3	L2	Critical	Manipulated commands; loss of view
A-11	Engineering workstation (EWS)	Z3	L2	Critical	Malware / credential theft -> PLC logic changes
A-12	Process historian	Z3	L3	High	Integrity of traceability data; availability
A-13	OPC UA server	Z3	L3	High	Unauthorized access; tag writes
A-14	PLC-01 Conveyor	Z4	L1	Critical	Unauthorized logic changes / stop commands
A-15	PLC-02 Robotic welding cell	Z4	L1	Critical	Parameter tampering -> defective welds, equipment damage
A-16	PLC-03 Packaging	Z4	L1	High	Disruption of shipping; labelling errors
A-17	Field devices (sensors, drives, actuators)	Z5	L0	High	Driven to unsafe/undesired states by PLC
A-18	Hardwired safety circuits	Z5	L0	Critical	Out of cyber scope - not networked (assumption)
A-19	IIoT gateway + LTE router	Z6	-	High	Uncontrolled OT/Internet bridge
A-20	Wireless vibration sensors (24)	Z6	L0	Low	Spoofed readings
A-21	Cloud analytics platform (SaaS)	Z6	-	Medium	Data exposure; malicious updates to gateway
A-22	Vendor remote support (RoboServ)	Z7	-	High	Third-party credential compromise
A-23	OT network switches	Z3	L2	High	Flat network; open ports in control cabinets

Appendix C - Data flows

ID	Source	Destination	Protocol	Boundary	Threats
DF-01	Operator	SCADA/HMI	Local console (keyboard/touch)	-	T-03, T-17
DF-02	SCADA/HMI	PLC-01/02/03	Modbus/TCP 502 (read/write)	TB-4	T-05, T-15, T-16, T-17, T-22, T-30
DF-03	Engineering WS	PLC-01/02/03	PLC engineering protocol (vendor proprietary)	TB-4	T-02, T-06, T-16, T-21, T-22, T-23, T-27, T-30
DF-04	PLC-01/02/03	Field devices	Hardwired I/O, 4-20 mA, fieldbus	TB-5	-
DF-05	PLC-01/02/03	OPC UA server	Modbus/TCP 502 (polled)	TB-4	T-05, T-16, T-20
DF-06	OPC UA server	Historian	OPC UA 4840 (SecurityMode None)	-	T-18, T-19, T-20
DF-07	Historian	Historian replica	SQL replication 1433 (bidirectional)	TB-3	T-18, T-29
DF-08	Business users / ERP	Historian replica	HTTPS reports, SQL	TB-2	T-04
DF-09	Vendor engineer	Remote-access gateway	SSL VPN over Internet	TB-7 / TB-1	T-01, T-26
DF-10	Remote-access gateway	Jump server	RDP 3389	-	T-07, T-25
DF-11	Jump server	Engineering WS	RDP 3389	TB-3	T-06, T-07, T-25
DF-12	IT administrator	Jump server	RDP 3389	TB-2	T-07, T-10, T-25
DF-13	OT Windows hosts	Active Directory	Kerberos, LDAP, SMB (direct)	TB-3 + TB-2 (bypasses IDMZ)	T-08, T-10
DF-14	OPC UA server	IIoT gateway	OPC UA 4840 subscription	TB-6	T-11, T-20
DF-15	Vibration sensors	IIoT gateway	Proprietary 2.4 GHz wireless	TB-6	T-14
DF-16	IIoT gateway	Cloud analytics	MQTT/TLS 8883 over LTE	TB-6	T-11, T-12
DF-17	Cloud analytics	IIoT gateway	HTTPS (device management)	TB-6	T-13
DF-18	Internet	Email / workstations	SMTP, HTTPS	TB-1	T-09
DF-19	Contractor USB media	Engineering WS / HMI	Removable media	Physical	T-28
DF-20	Internet (TeamViewer)	Engineering WS	TeamViewer (outbound-initiated)	Bypasses TB-1..TB-3	T-24